

Notas do apresentador — Escalando uma autenticação legada para sistemas distribuídos

Roteiro seguindo a ordem dos slides de `src/main.tex`, contendo apenas os slides com notas.

Objetivo

- Boa tarde, pessoal. Hoje eu vou falar sobre os desafios de escalar uma auth legada para sistemas distribuídos.
 - A ideia aqui não é falar de uma arquitetura perfeita.
 - Falar de como a demanda veio.
 - Falar de não onerar os desenvolvedores.
 - Falar que não podia pensar apenas em código porque havia vários sistemas.
 - Falar como foi bom para a carreira.
-

Seção: Motivação

Autenticação no backend

- Se estiver assim já tá ótimo, isso quando o cookie não é enviado no body.

O caos

- Chave estática por serviço não escala: cada novo consumidor é mais uma chave hardcoded, sem expiração, sem rotação, e sem saber quem realmente está chamando.
 - Até que o sistema cresceu ainda mais, o serviço A não pode acessar o B. O usuário X não pode acessar o serviço C e por aí vai.
 - A gente chegou nesse ponto: a arquitetura cresceu, mas a nossa autenticação não cresceu junto.
-

Seção: JWT

Como validar sem depender do servidor?

- Uma característica importante do JWT é que ele é autocontido.
- Depois que eu emito esse token, qualquer serviço que consiga validar a assinatura pode aceitá-lo até o momento em que ele expire.
- Eu não preciso consultar o Authorization Server a cada requisição.

Retomando exemplo de validação

- Preciso armazenar apenas o SECRET, não o token.

Quem pode usar esse token? (Bearer)

- Analogia da pulseira da festa.
 - Stateless.
-

Seção: OAuth2 e OIDC

O problema

- Voltando ao exemplo anterior, imagine que o produto deu certo e o sistema escalou bastante: criamos vários microserviços, mas todos dependentes do backend.
- É um caso real meu, porque a empresa tem inúmeros microserviços, cada um com um sistema de auth. Seria inviável alterar o código de cada um. Pior de tudo que temos que atualizar sem quebrar.

Como delegar acesso sem distribuir a credencial? (OAuth2)

- Tudo isso que acabamos de ver — emitir, revogar, blacklist, controle de acesso — hoje é feito manualmente por cada equipe, sem um padrão em comum.
- O problema agora é: como delegar acesso sem distribuir a credencial original?
- O OAuth2 não resolve isso com uma técnica específica; ele fornece um framework de autorização, com papéis e fluxos padronizados, pra essa delegação.

Como autenticar serviço a serviço? (Client Credentials)

- Aqui o segredo já não dá acesso direto à API: ele é usado só pra obter, junto ao Authorization Server, um token com escopo e duração controlados.
- Isso já é uma melhoria operacional grande em relação à API Key estática.

M2M: o problema

- Mas olha só: o cliente ainda precisa guardar um segredo estático pra fazer essa troca.
- O problema de gerenciar a credencial do workload continua existindo — só mudou de lugar.

Fluxo Implementado

- Se vocês não entenderam nada, não se preocupem: eu também não entendi na 1ª, 2ª nem na 3ª vez que estudei isso.
- E vejam a complexidade disso.

Como carregar a identidade do usuário? (ID Token)

- Falar do case bancário.
 - KYC, pwd, etc.
-

Seção: Arquitetura

O que mudou?

- É assim que escalamos uma autenticação legada.